

RELATÓRIO DE LABORATÓRIO PRÁTICO

Bloqueio de URLs maliciosas com AWS Network Firewall e Suricata

Inspeção stateful, regras IPS personalizadas e validação antes/depois

Autor	José Airton de Carvalho Neto
Formação	AWS re/Start - Escola da Nuvem
Área	Cloud Security - Network Firewall - Suricata IPS
Data	24 de agosto de 2026

Resultado: Duas URLs de teste foram bloqueadas após a aplicação de regras Suricata em um grupo stateful associado à política do firewall.

AWS | Segurança | Operações | Evidências práticas

1. Visão geral

O laboratório simulou a proteção de uma instância EC2 contra downloads de conteúdo malicioso. Primeiro foi comprovado que os arquivos estavam acessíveis. Em seguida, o AWS Network Firewall foi configurado para encaminhar o tráfego à inspeção stateful e aplicar assinaturas Suricata com ação drop.

Objetivo: Bloquear requisições HTTP específicas, validar a sincronização da política e demonstrar o controle por meio de um teste antes/depois.

1.1 Arquitetura lógica

Fluxo: Instância EC2 -> rota da VPC -> endpoint do Network Firewall -> política LabFirewallPolicy -> StatefulRuleGroup -> permitir ou descartar tráfego

1.2 Componentes

- Instância EC2 TestInstance acessada por AWS Systems Manager Session Manager.
- AWS Network Firewall associado à VPC do laboratório.
- Política LabFirewallPolicy com encaminhamento para grupos de regras stateful.
- Grupo StatefulRuleGroup, capacidade 100 e ordem de ação padrão.
- Duas assinaturas IPS compatíveis com Suricata e ação drop.

1.3 Critérios de sucesso

Etapa	Comportamento esperado	Evidência
Antes	Downloads HTTP concluídos	HTTP 200 e arquivos salvos
Configuração	Política e grupo sincronizados	Estado Em sincronia
Depois	Downloads impedidos	Requisições sem conclusão e arquivos ausentes

2. Linha de base: tráfego permitido

Antes da proteção, a instância realizou requisições com wget para dois caminhos de teste. O servidor respondeu com HTTP 200 e os arquivos foram gravados localmente, comprovando que o caminho de rede estava aberto.

```
sh-4.2$ cd /
sh-4.2$ pwd
/home/ssm-user
sh-4.2$ wget http://malware.wicar.org/data/js_crypto_miner.html
--2026-08-24 05:30:56-- http://malware.wicar.org/data/js_crypto_miner.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:806:16a08
Connecting to malware.wicar.org (malware.wicar.org)[208.94.116.246:80...] wget http://malware.wicar.org/data/js_crypto_miner.html
HTTP request sent, awaiting response... 200 OK
Length: 366 [text/html]
Saving to: 'js_crypto_miner.html'

100%[=====] 366 --.-/s in 0s

2026-08-24 05:31:10 (71.6 MB/s) - 'js_crypto_miner.html' saved [366/366]

sh-4.2$ ls
js_crypto_miner.html
sh-4.2$
```

Figura 1 - Downloads concluídos antes da aplicação das regras de bloqueio.

Leitura técnica: A evidência inicial evita um falso positivo de validação: o bloqueio posterior só é significativo porque a conectividade foi comprovada antes da mudança.

3. Implementação do controle

3.1 Encaminhamento para inspeção stateful

As ações padrão sem estado da política foram alteradas para encaminhar pacotes completos e fragmentados aos grupos de regras com estado. Essa configuração permite que o firewall acompanhe o contexto da conexão.

3.2 Grupo de regras e assinaturas Suricata

Regra	URI inspecionada	SID	Ação
1	/data/js_crypto_miner.html	2002001	drop
2	/data/java_jre17_exec.html	2002002	drop

O grupo foi criado em modo stateful, com capacidade 100 e ordem de ação padrão. A escolha da ordem de ação foi necessária porque as assinaturas continham a palavra-chave classtype, incompatível com strict order nesse cenário.

Adicionar outra variável de portas

▼ Referências ao conjunto de IPs - *opcional* Informações

A referência ao conjunto de IPs é uma variável usada em suas regras que faz referência a um recurso associado a uma lista de IPs ou CIDRs.

Nome da variável: ID do recurso:

Insira um nome para a variável. Escolha um ID para associar ao nome da variável.

CIDRs:

O número de CIDRs usados por esse recurso.

Remover

Adicionar referência ao conjunto de IPs

Você pode adicionar até 4 mais referências ao conjunto de IPs.

Utilização de CIDR

O número total de CIDRs usados pelas referências ao conjunto de IPs em todo o firewall.

0/1,000,000

String de regra compatível com Suricata Informações

O Suricata é um IPS de rede de código aberto que inclui uma linguagem padrão baseada em regras para inspeção de tráfego.

String de regra compatível com Suricata

Copiar regras

Cancelar Anterior Próximo

Figura 2 - Regras Suricata inseridas no grupo stateful.

4. Associação e sincronização

O StatefulRuleGroup foi associado como grupo não gerenciado à LabFirewallPolicy. A política e o grupo apareceram em sincronia na zona de disponibilidade do laboratório, indicando propagação bem-sucedida.

The screenshot displays the AWS Network Firewall console interface. On the left, a navigation pane shows the hierarchy: **Segurança** (Security) > **PrivateLink e Lattice** > **Firewall de DNS** > **Network Firewall** > **Firewalls**. The main content area is titled 'LabFirewall' and contains three sections:

- Endpoints de firewall**: A table with one entry.

Zona de disponibi...	Sub-rede do fire...	ID do endpoint	Status do endpoi...
us-west-2a	subnet-0cd02130...	vpce-0e2b93910a...	Pronto
- Política de firewall**: A section showing the associated policy 'LabFirewallPolicy' with an 'Editar' (Edit) button.
- Estado de sincronização da configuração**: A table showing the synchronization status of resources.

Nome do recurso	Tipo do recurso	Zona de disponib...	Estado de sincro...
LabFirewallPolicy	Política de firewall	us-west-2a	Em sincronia
StatefulRuleGroup	Grupo de regras c...	us-west-2a	Em sincronia

Figura 3 - Política e grupo de regras em estado Em sincronia.

Controle de mudança: A sincronização deve ser confirmada antes do reteste. Caso contrário, um resultado permissivo poderia ocorrer apenas por atraso de propagação.

5. Validação do bloqueio

Após a sincronização, as mesmas requisições foram repetidas. As conexões não concluíram e os arquivos não foram gravados, demonstrando que o tráfego correspondente às assinaturas foi descartado pelo firewall.

```
sh-4.2$ cd /home/ssm-user
sh-4.2$ wget http://malware.wicar.org/data/js_crypto_miner.html
--2026-08-24 05:50:11-- http://malware.wicar.org/data/js_crypto_miner.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:806:16a08
Connecting to malware.wicar.org (malware.wicar.org) [208.94.116.246]:80... connected.
HTTP request sent, awaiting response... 404
sh-4.2$ wget http://malware.wicar.org/data/java_jre17_exec.html
--2026-08-24 05:50:46-- http://malware.wicar.org/data/java_jre17_exec.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:806:16a08
Connecting to malware.wicar.org (malware.wicar.org) [208.94.116.246]:80... connected.
HTTP request sent, awaiting response... 404
sh-4.2$ rm java_jre17_exec.html js_crypto_miner.html
sh-4.2$ ls
sh-4.2$
```

Figura 4 - Reteste após a proteção: downloads impedidos pelas regras stateful.

Teste	Antes	Depois	Resultado
js_crypto_miner.html	Baixado	Bloqueado	Aprovado
java_jre17_exec.html	Baixado	Bloqueado	Aprovado

6. Análise crítica e segurança

6.1 Controles aplicados

- Inspeção stateful para considerar o contexto da conexão.
- Assinaturas específicas com identificadores únicos para rastreabilidade.
- Validação antes/depois para demonstrar causalidade.
- Uso do Session Manager, evitando exposição direta de SSH à internet.

6.2 Limitações e riscos

- As regras utilizadas inspecionam caminhos HTTP específicos; mudanças de URI podem exigir novas assinaturas.
- Tráfego HTTPS exige estratégia de inspeção TLS para observar conteúdo criptografado.
- Um firewall não substitui proteção de endpoint, atualização de sistemas, IAM restrito e monitoramento.
- Ambientes reais devem registrar logs de alerta e fluxo no CloudWatch Logs ou em um SIEM.

Trade-off: Regras altamente específicas reduzem falsos positivos, porém apresentam menor cobertura. Regras genéricas ampliam a detecção, mas podem bloquear tráfego legítimo.

Metodologia e transparência

A execução das configurações, testes e validações no ambiente AWS foi realizada pelo autor. Ferramentas de inteligência artificial foram utilizadas como apoio didático, revisão textual e organização da documentação. As conclusões foram baseadas nas evidências observadas durante o laboratório.

Conclusão

O laboratório demonstrou, de ponta a ponta, como o AWS Network Firewall pode aplicar políticas IPS personalizadas com Suricata. O resultado foi validado por evidências de conectividade anterior, sincronização da política e bloqueio posterior, formando um registro técnico reproduzível para portfólio.